

Data Processing Agreement

Lexy AI Hiring Platform

Version 1.0 — last updated 16 May 2026

This Data Processing Agreement ("**DPA**") forms part of the Master Services Agreement, Subscription Agreement, Order Form, or other written or electronic agreement between Lexy Inc. and the Customer for the provision of the Lexy AI hiring platform (the "**Principal Agreement**"). This DPA reflects the parties' agreement with respect to the Processing of Personal Data by Lexy on behalf of Customer.

1. Parties

Processor: Lexy Inc., a Delaware corporation ("**Lexy**"), with notices addressed to `legal@l3xy.ai`.

Controller: The customer entity identified in the Principal Agreement (the "**Customer**").

Together, the "**Parties**"; each, a "**Party**".

2. Definitions

Capitalised terms not defined here have the meanings given in the Principal Agreement or in the GDPR.

- "**Applicable Data Protection Law**" means all laws and regulations applicable to the Processing of Personal Data under this DPA, including (as applicable) the EU General Data Protection Regulation 2016/679 ("**GDPR**"), the UK Data Protection Act 2018 and UK GDPR, the California Consumer Privacy Act as amended by the CPRA ("**CCPA**"), and other US state privacy laws.
- "**Personal Data**", "**Processing**", "**Controller**", "**Processor**", "**Data Subject**", and "**Personal Data Breach**" have the meanings given in Article 4 of the GDPR.
- "**Customer Personal Data**" means Personal Data Processed by Lexy on behalf of Customer under the Principal Agreement.
- "**Subprocessor**" means any third party engaged by Lexy to Process Customer Personal Data.
- "**Standard Contractual Clauses**" or "**SCCs**" means the European Commission's standard contractual clauses for the transfer of personal data to third countries (Commission Decision 2021/914), and where applicable the UK Addendum issued by the ICO.

3. Scope and Roles

3.1. This DPA applies to all Processing of Customer Personal Data by Lexy in the course of providing the Lexy AI hiring platform under the Principal Agreement.

3.2. The Parties acknowledge that with respect to Customer Personal Data, Customer is the **Controller** (or in CCPA terms, the **Business**) and Lexy is the **Processor** (or **Service Provider**). For CCPA purposes, Lexy will not "sell" or "share" Customer Personal Data and will not retain, use, or disclose it outside of the direct business relationship between Customer and Lexy or otherwise as permitted by the CCPA.

3.3. Lexy may also Process certain Personal Data as an independent Controller (for example, account administrator contact details and usage telemetry necessary to operate the service). This DPA does not govern that independent Controller processing, which is described in Lexy's Privacy Policy.

4. Details of Processing

The subject matter, duration, nature and purpose of the Processing, the categories of Data Subjects and the types of Personal Data are described in **Annex A** to this DPA.

5. Customer Instructions

5.1. Lexy will Process Customer Personal Data only on documented instructions from Customer, including with regard to international transfers, except where required to do so by law applicable to Lexy (in which case Lexy will inform Customer of that legal requirement before Processing, unless that law prohibits such notice on important grounds of public interest).

5.2. The Principal Agreement, the Order Form, this DPA, and Customer's use of features and configurations of the Lexy platform together constitute Customer's complete and final documented instructions to Lexy. Any additional or alternative instructions must be agreed in writing.

5.3. Lexy will inform Customer if, in its opinion, an instruction infringes Applicable Data Protection Law.

6. Lexy's Obligations (GDPR Article 28(3))

Lexy will:

- (a) Process Customer Personal Data only on documented instructions from Customer, as set out in Section 5;
- (b) ensure that personnel authorised to Process Customer Personal Data are bound by appropriate confidentiality undertakings;

- (c) take all measures required pursuant to Article 32 of the GDPR (security of Processing), as further described in Section 9 and **Annex B**;
- (d) respect the conditions in Sections 7 and 8 for engaging Subprocessors;
- (e) taking into account the nature of the Processing, assist Customer by appropriate technical and organisational measures, insofar as possible, in fulfilling Customer's obligation to respond to Data Subject requests under Chapter III of the GDPR;
- (f) assist Customer in ensuring compliance with its obligations under Articles 32 to 36 of the GDPR (security, breach notification, data protection impact assessments, and consultation with supervisory authorities), taking into account the nature of the Processing and the information available to Lexy;
- (g) at Customer's choice, delete or return all Customer Personal Data after the end of the provision of services, as set out in Section 13; and
- (h) make available to Customer all information necessary to demonstrate compliance with this Section 6, and allow for and contribute to audits as set out in Section 12.

7. Subprocessors

7.1. Customer grants Lexy a **general authorisation** to engage Subprocessors to Process Customer Personal Data, subject to the conditions in this Section 7. A current list of authorised Subprocessors is set out in **Annex C** and on Lexy's website at l3xy.ai/dpa.

7.2. Before engaging any new Subprocessor (or replacing an existing one), Lexy will notify Customer at least **thirty (30) days** in advance by updating Annex C and emailing the account administrator(s) on record. Customer may object on reasonable data-protection grounds within fifteen (15) days of receiving such notice. If Customer reasonably objects and the Parties cannot agree on a resolution, Customer may terminate the affected portion of the services without penalty by providing written notice within a further fifteen (15) days.

7.3. Lexy will impose data protection obligations on each Subprocessor that are substantially equivalent to those set out in this DPA, in particular providing sufficient guarantees to implement appropriate technical and organisational measures so that the Processing meets the requirements of Applicable Data Protection Law.

7.4. Lexy remains fully liable to Customer for the performance of each Subprocessor's obligations.

8. International Data Transfers

8.1. Lexy is established in the United States. Customer acknowledges that Lexy and its Subprocessors may Process Customer Personal Data in the United States and other jurisdictions outside the European Economic Area, the United Kingdom, and Switzerland.

8.2. Where Customer Personal Data subject to GDPR or UK GDPR is transferred from the EEA, the United Kingdom, or Switzerland to a country that has not received an adequacy decision, the Parties agree that the **EU Standard Contractual Clauses** (Module Two: Controller to Processor)

are hereby incorporated into this DPA by reference and are entered into between Customer (as data exporter) and Lexy (as data importer), with the following selections:

- **Clause 7 (Docking clause):** included.
- **Clause 9 (Subprocessors):** Option 2 (general written authorisation), with the 30-day notice period set out in Section 7.2.
- **Clause 11 (Redress):** the optional independent-dispute-resolution language is **not** included.
- **Clause 17 (Governing law):** the law of the Republic of Ireland.
- **Clause 18 (Forum and jurisdiction):** the courts of Ireland.
- **Annexes I, II, III:** populated by Annexes A, B, and C of this DPA respectively.

8.3. For transfers from the United Kingdom, the **UK International Data Transfer Addendum** issued by the ICO under section 119A of the UK Data Protection Act 2018 (as updated from time to time) is incorporated and applies to the SCCs, with the tables completed as follows: Table 1 (Parties) — as identified in this DPA; Table 2 (Selected SCCs) — Module Two as described above; Table 3 (Appendix Information) — Annexes A, B, C of this DPA; Table 4 (Ending the Addendum) — neither Party may end the Addendum unilaterally under Section 19.

8.4. For transfers from Switzerland, the SCCs apply with references to GDPR construed as references to the Swiss Federal Act on Data Protection where applicable, and references to supervisory authorities and courts of the EU Member States construed as the Swiss Federal Data Protection and Information Commissioner and courts of Switzerland.

9. Security

9.1. Lexy will implement and maintain appropriate technical and organisational measures designed to protect Customer Personal Data against accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, Personal Data. These measures are described in **Annex B**.

9.2. Lexy may update Annex B from time to time provided that the updated measures do not materially decrease the overall level of protection of Customer Personal Data.

10. Personal Data Breach

10.1. Lexy will notify Customer **without undue delay**, and in any event within **seventy-two (72) hours**, after becoming aware of a Personal Data Breach affecting Customer Personal Data.

10.2. The notification will, at minimum and to the extent then known: (a) describe the nature of the Personal Data Breach including, where possible, the categories and approximate number of Data Subjects and records concerned; (b) describe the likely consequences of the breach; (c) describe the measures taken or proposed to be taken to address the breach and to mitigate its possible adverse effects; and (d) provide a point of contact for further information.

10.3. Lexy will reasonably cooperate with Customer in its handling of the breach, including assisting with any required notifications to supervisory authorities and affected Data Subjects.

11. Data Subject Requests

11.1. Lexy will, taking into account the nature of the Processing, provide reasonable assistance through appropriate technical and organisational measures to enable Customer to respond to requests from Data Subjects exercising their rights under Applicable Data Protection Law (including rights of access, rectification, erasure, restriction, portability, and objection, and the right not to be subject to automated decisions).

11.2. If a Data Subject submits a request directly to Lexy concerning Customer Personal Data, Lexy will promptly forward the request to Customer and will not respond to the Data Subject substantively without Customer's instruction, except to confirm receipt and to identify the Customer as the responsible Controller.

12. Audits

12.1. Lexy will make available to Customer all information reasonably necessary to demonstrate compliance with this DPA. On Customer's written request not more than **once per twelve (12) months** (except where required by a supervisory authority or following a confirmed Personal Data Breach), Lexy will provide responses to a reasonable security questionnaire and copies of relevant third-party audit reports (such as SOC 2 Type II or ISO 27001 certifications) where available.

12.2. Where the information made available under Section 12.1 is insufficient to demonstrate compliance, Customer may, on at least thirty (30) days' prior written notice and not more than once per twelve (12) months, conduct an on-site audit of Lexy's facilities and operations relevant to the Processing of Customer Personal Data. The audit will be conducted during normal business hours, with minimal disruption to Lexy's operations, subject to confidentiality undertakings, and at Customer's expense. Customer may use an independent third-party auditor that is not a competitor of Lexy and that is bound by confidentiality obligations no less protective than those between the Parties.

13. Return and Deletion

13.1. On termination or expiry of the Principal Agreement, Lexy will, at Customer's choice, delete or return all Customer Personal Data to Customer.

13.2. Customer may export its Customer Personal Data at any time during the term of the Principal Agreement using the export features made available by the Lexy platform.

13.3. Unless Customer instructs otherwise in writing, Lexy will delete all Customer Personal Data within **ninety (90) days** of the termination or expiry of the Principal Agreement, subject to the limited retention permitted by Section 13.4.

13.4. Lexy may retain Customer Personal Data to the extent required by applicable law, in encrypted backups for up to twelve (12) months pending overwrite in the ordinary course, or in fully anonymised form that no longer constitutes Personal Data.

14. Customer Obligations

14.1. Customer warrants that it has all necessary rights to provide the Customer Personal Data to Lexy for the Processing contemplated by this DPA, including that it has obtained any consents and provided any notices required under Applicable Data Protection Law.

14.2. Customer is solely responsible for the accuracy, quality, and legality of Customer Personal Data and the means by which Customer acquired it.

14.3. Customer will configure and use the Lexy platform in a manner that complies with Applicable Data Protection Law, and will not instruct Lexy to Process Customer Personal Data in a manner that would violate it.

15. Liability

The liability of each Party (and each Party's affiliates) arising out of or in connection with this DPA, whether in contract, tort, or under any other theory of liability, is subject to the exclusions and limitations of liability set out in the Principal Agreement. Nothing in this DPA limits or excludes liability that cannot lawfully be limited or excluded under Applicable Data Protection Law.

16. General

16.1. **Order of precedence.** In the event of any conflict between this DPA and the Principal Agreement, this DPA prevails with respect to the subject matter of this DPA. In the event of any conflict between this DPA and the SCCs, the SCCs prevail.

16.2. **Governing law.** Except as otherwise provided in the SCCs (which are governed as set out in Section 8.2), this DPA is governed by the laws of the State of Delaware, United States, without regard to its conflict of laws principles.

16.3. **Severability.** If any provision of this DPA is held to be invalid or unenforceable, the remaining provisions remain in full force and effect.

16.4. **Counterparts and electronic signature.** This DPA may be executed in counterparts, including by electronic signature, each of which is an original and all of which together constitute one instrument.

Signatures

	Customer	Lexy Inc.
Signed by	_____	_____
Name	_____	_____
Title	_____	_____
Date	_____	_____

Annex A — Details of Processing

Subject matter of the Processing. Provision of the Lexy AI hiring platform, comprising AI-conducted candidate interviews, automated candidate assessment and scoring, career profiling, job matching, and recruitment workflow automation.

Duration of the Processing. For the term of the Principal Agreement, plus the limited retention period set out in Section 13.

Nature and purpose of the Processing. Collection, storage, organisation, structuring, retrieval, consultation, use, disclosure (to authorised users within Customer's organisation), transmission, alignment, combination, restriction, erasure, and destruction of Customer Personal Data, in each case for the purpose of providing the Lexy platform to Customer.

Categories of Data Subjects.

- Candidates applying for or being assessed for roles posted by Customer;
- Customer's employees and authorised users who use the Lexy platform;
- Other individuals whose Personal Data Customer chooses to upload to the platform (e.g. employee referrals).

Categories of Personal Data.

- Identity data: name, email, phone number;
- Professional data: CV/résumé content, employment and education history, skills, qualifications;
- Interview data: audio recordings, video recordings (where enabled), text transcripts, AI-generated assessments and scores;
- Career profile data: career goals, strengths, preferences, AI-generated insights;
- Technical data: IP address, browser type, device identifiers, session identifiers;
- Authentication data: hashed passwords, MFA factors, session tokens.

Special categories of Personal Data. Lexy does not request special-category data and instructs Customer not to upload it. Incidental special-category data may appear in free-text fields (e.g. a CV mentioning a disability accommodation). Customer is responsible for ensuring it has a lawful basis under Article 9 of the GDPR for any such data.

Frequency of Processing. Continuous, for the term of the Principal Agreement.

Annex B — Technical and Organisational Measures

Lexy implements the following technical and organisational measures pursuant to Article 32 of the GDPR.

Encryption.

- Data in transit is encrypted using TLS 1.2 or higher (TLS 1.3 preferred), with strong cipher suites and certificate pinning where appropriate.
- Data at rest is encrypted using AES-256 (or equivalent), with keys managed by the cloud provider's KMS.

Access control.

- Role-based access control (RBAC) limits employee access to Customer Personal Data on a need-to-know basis.
- Multi-factor authentication is required for all employee and administrator access to production systems.
- All access to production systems is logged and reviewed.
- Customer's own user access to the platform is governed by per-tenant authentication, with tenant-scoped row-level security in the database for the most sensitive resources.

Network security.

- Production systems are deployed in private network segments behind a managed load balancer.
- Public endpoints are protected by HTTPS-only, CORS allowlisting, CSRF protection on cookie-authenticated state-changing routes, and per-IP and per-resource rate limiting on authentication-sensitive endpoints.

Application security.

- Passwords are hashed using bcrypt with an appropriate work factor.
- Input is validated using strict schema-based validation.
- Dependencies are monitored for known vulnerabilities and patched on a regular cadence.
- Static analysis and code review are performed before changes reach production.

Operational security.

- Production deployments are version-controlled and auditable.
- Backups are taken daily and retained for at least thirty (30) days, encrypted at rest.
- Logs are retained for a minimum of ninety (90) days and reviewed for security events.

Incident response.

- Lexy maintains a documented incident-response plan with defined roles, escalation paths, and notification timelines that support the 72-hour Personal Data Breach notification commitment in Section 10.

Personnel.

- All employees are bound by written confidentiality obligations.
- Employees with access to Customer Personal Data complete security and privacy training on hire and annually thereafter.
- Access is revoked promptly on termination.

Subprocessor management.

- Subprocessors are assessed for security and privacy posture before engagement and reviewed periodically thereafter.
- Subprocessors are bound by written data protection terms substantially equivalent to those in this DPA.

Annex C — Authorised Subprocessors

The current list of authorised Subprocessors is set out below. The list is also maintained at l3xy.ai/dpa and will be updated in accordance with Section 7.2.

Subprocessor	Purpose	Location of Processing
Amazon Web Services, Inc.	Cloud infrastructure (compute, storage, database, networking)	United States (with optional regional residency on request)
OpenAI, L.L.C.	Large-language-model inference for candidate interviews and assessments	United States
Microsoft Corporation (Azure)	Speech-to-text and text-to-speech for voice interviews	United States and European Union
Stripe, Inc.	Payment processing for customer subscriptions (Customer billing data only; not Candidate data)	United States

Postmark / SendGrid (transactional email)	Transactional email delivery (account confirmations, interview invitations, password resets)	United States
Sentry / Datadog (observability)	Error monitoring and performance observability	United States and European Union

End of DPA.